

NIMBUSGUARD TECHNOLOGIES, INC.

Identity and Access Management Policy

Authentication, Authorization, Privileged Access & SSO Controls

Document ID:	NG-IAM-007	Version:	3.5
Effective Date:	February 10, 2026	Owner:	CISO – Dr. Elena Vasquez
Classification:	Internal – Confidential	Status:	Approved

1. Authentication

1.1 Single Sign-On

NimbusGuard enforces Single Sign-On (SSO) via Okta for all corporate and production systems. SSO is configured with SAML 2.0 and supports OIDC for modern applications. Password-only authentication is not permitted for any system.

1.2 Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for all users across all systems without exception. Approved MFA methods: hardware security keys (YubiKey – preferred, required for privileged accounts), Okta Verify push notifications (phishing-resistant with number matching), and time-based one-time passwords (TOTP) as a fallback only. SMS-based MFA is explicitly prohibited.

1.3 Password Policy

Where passwords are used alongside MFA: minimum 14 characters; must not appear in known breach databases (checked against HaveIBeenPwned API); no character composition rules (per NIST SP 800-63B); maximum password age of 365 days; passwords stored using bcrypt with a work factor of 12.

2. Authorization

Authorization follows the principle of least privilege. Access is granted based on Role-Based Access Control (RBAC) with the following controls:

- Roles are defined in Okta and mapped to application-specific permissions
- All role assignments require manager approval via automated workflow
- Access is reviewed quarterly through automated access certification campaigns (SailPoint)
- Dormant accounts (no login for 90 days) are automatically disabled
- Service accounts require a designated human owner and are reviewed semi-annually

3. Privileged Access Management

Privileged access to production systems is controlled through CyberArk Privileged Access Management:

- All privileged sessions are brokered through CyberArk's Privileged Session Manager (PSM) with full session recording
- Standing privileged access is prohibited; all access is just-in-time (JIT) with a maximum session duration of 4 hours
- Break-glass accounts exist for emergency access and require dual authorization plus documented justification
- All privileged actions are logged, correlated in the SIEM, and reviewed weekly by the security team

4. API and Service Authentication

API authentication uses short-lived OAuth 2.0 bearer tokens (maximum lifetime: 1 hour) issued by the NimbusGuard authorization server. Service-to-service authentication uses mutual TLS (mTLS) with

certificates issued by an internal PKI (HashiCorp Vault) and rotated every 24 hours. API keys are supported as a secondary mechanism for machine-to-machine integrations and are scoped to specific IP ranges and permissions.

5. Access Reviews

Review Type	Scope	Frequency	Owner
User access certification	All user accounts	Quarterly	People Managers
Privileged access review	Admin/root accounts	Monthly	CISO
Service account review	All service accounts	Semi-annually	System Owners
Third-party access review	Vendor/partner accounts	Quarterly	Vendor Manager
Orphaned account scan	All identity providers	Monthly (automated)	IAM Team